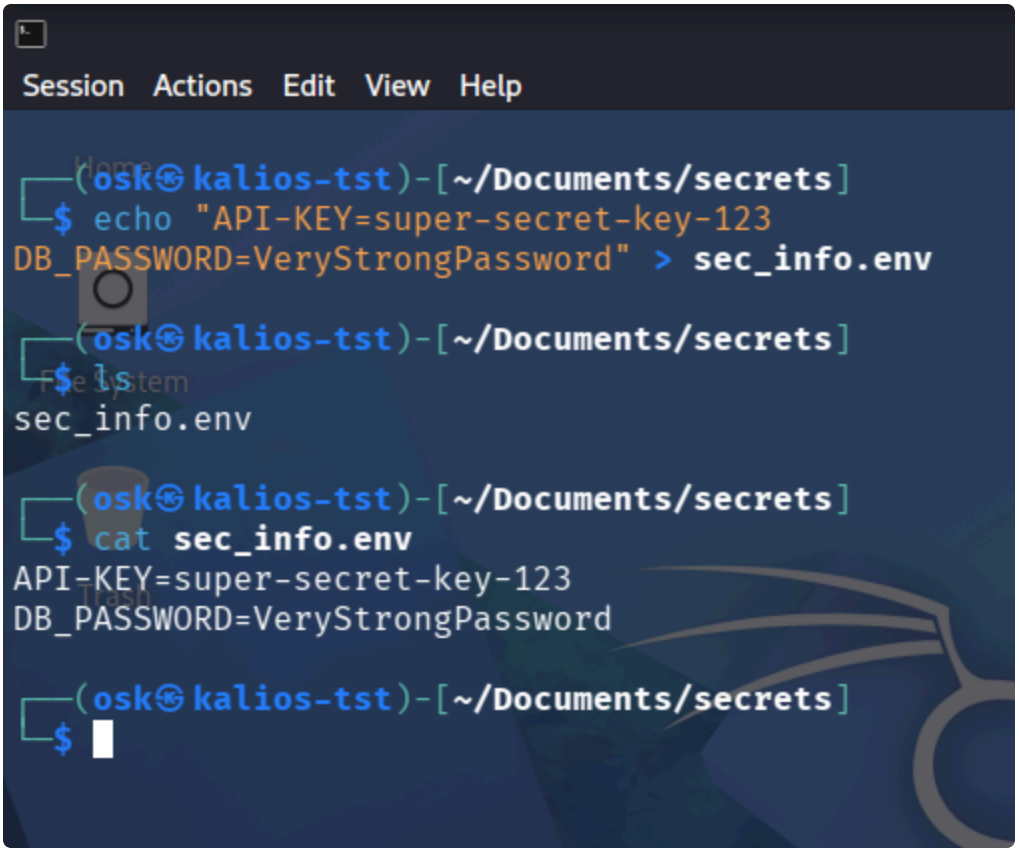
Lab06

#cyber-security

1 - Preparing the Secret:

To simulate the scenario, we first create the sample secret file:

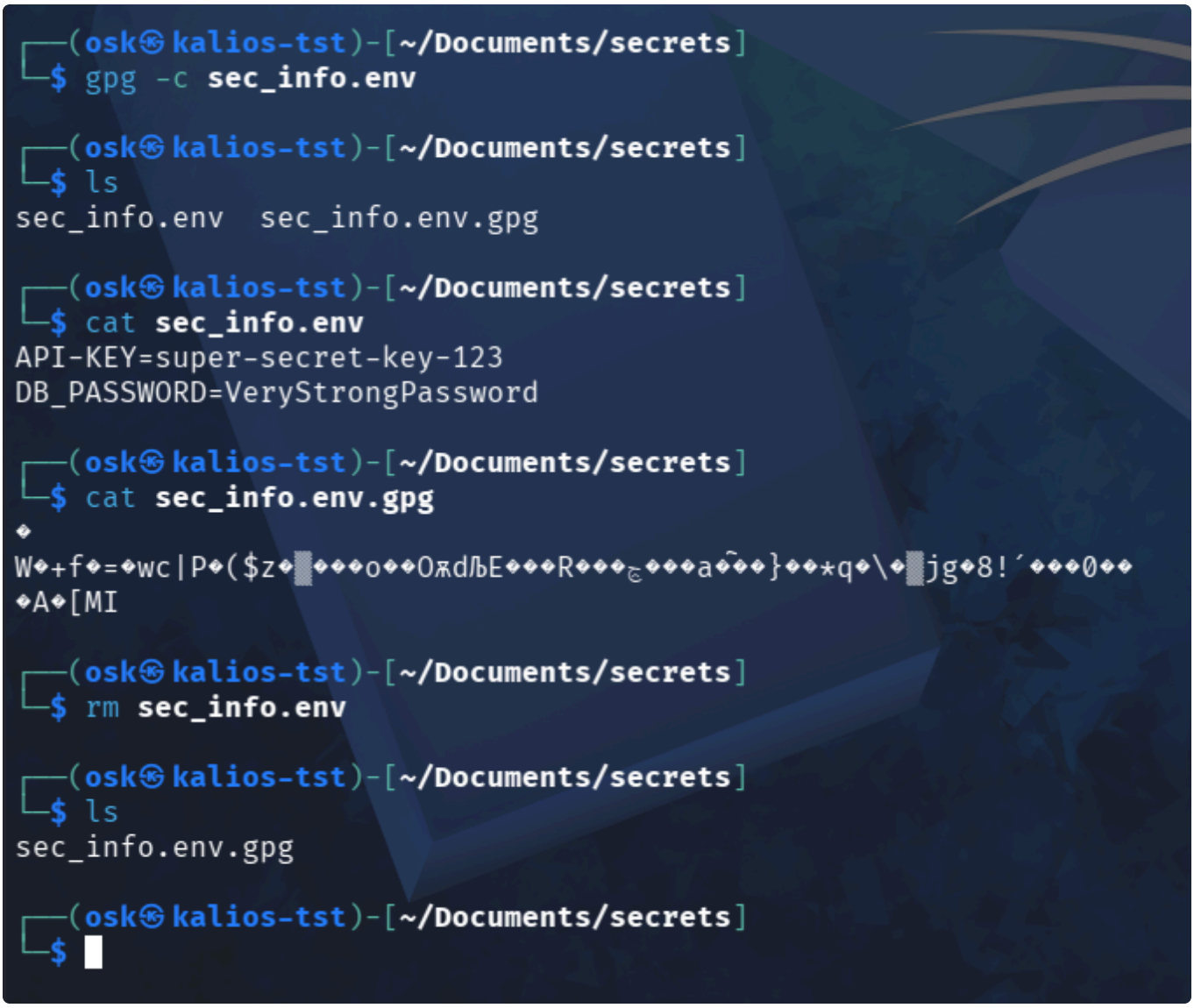
```
echo "API-KEY=super-seret-key-123
DB_PASSWORD=VeryStrongPassword" > sec_info.env
```



2 - Symmetric Encryption:

We can use gpg to symmetrically encrypt the file using a passphrase then delete the original

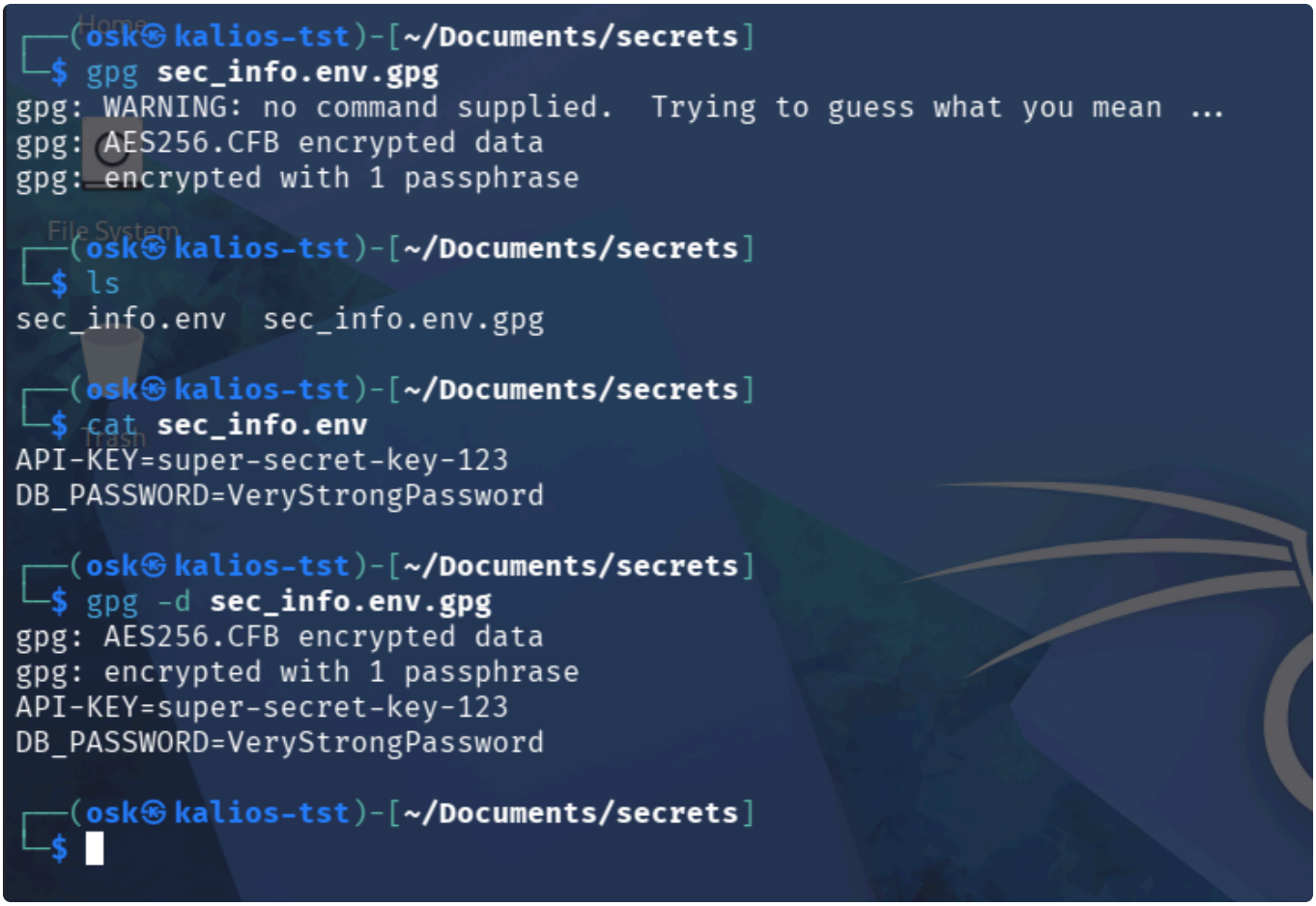
`gpg -c sec_info.env`



3 - Decryption and Access:

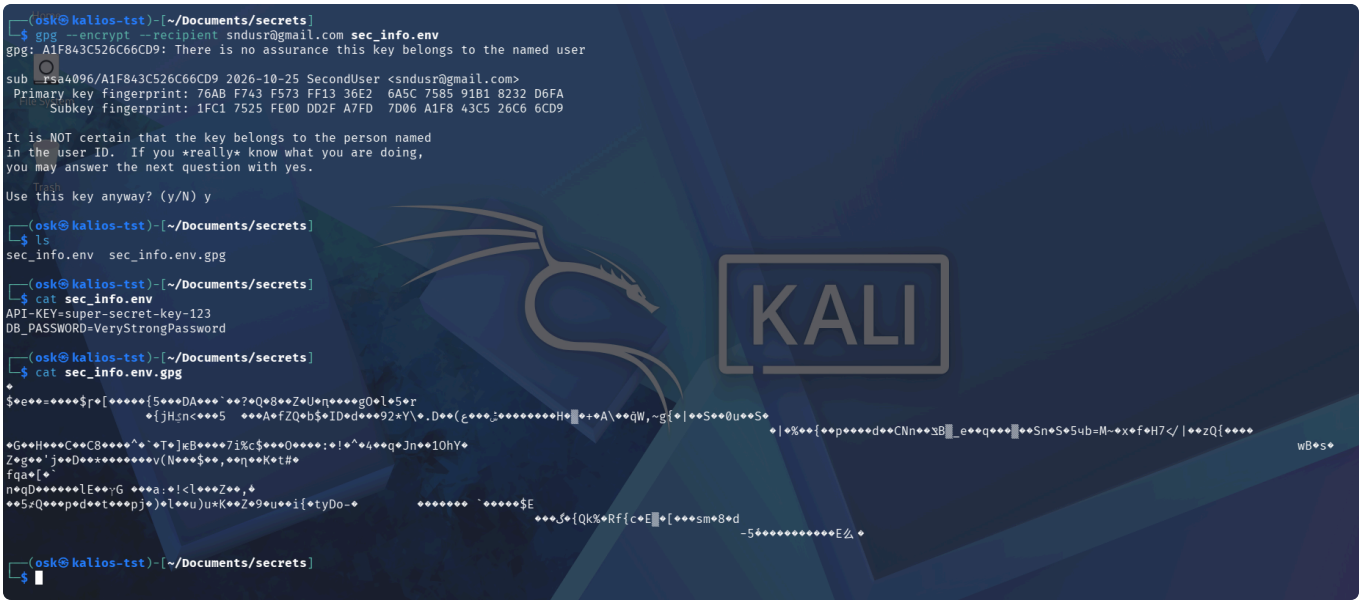
When having to access the file, the command `gpg SECRET_FILE` can be ran which will decrypt the contents and store them in what the file originally was, here `sec_info.env`. Alternatively,

adding the -d argument will just decrypt the contents and display them within the terminal.



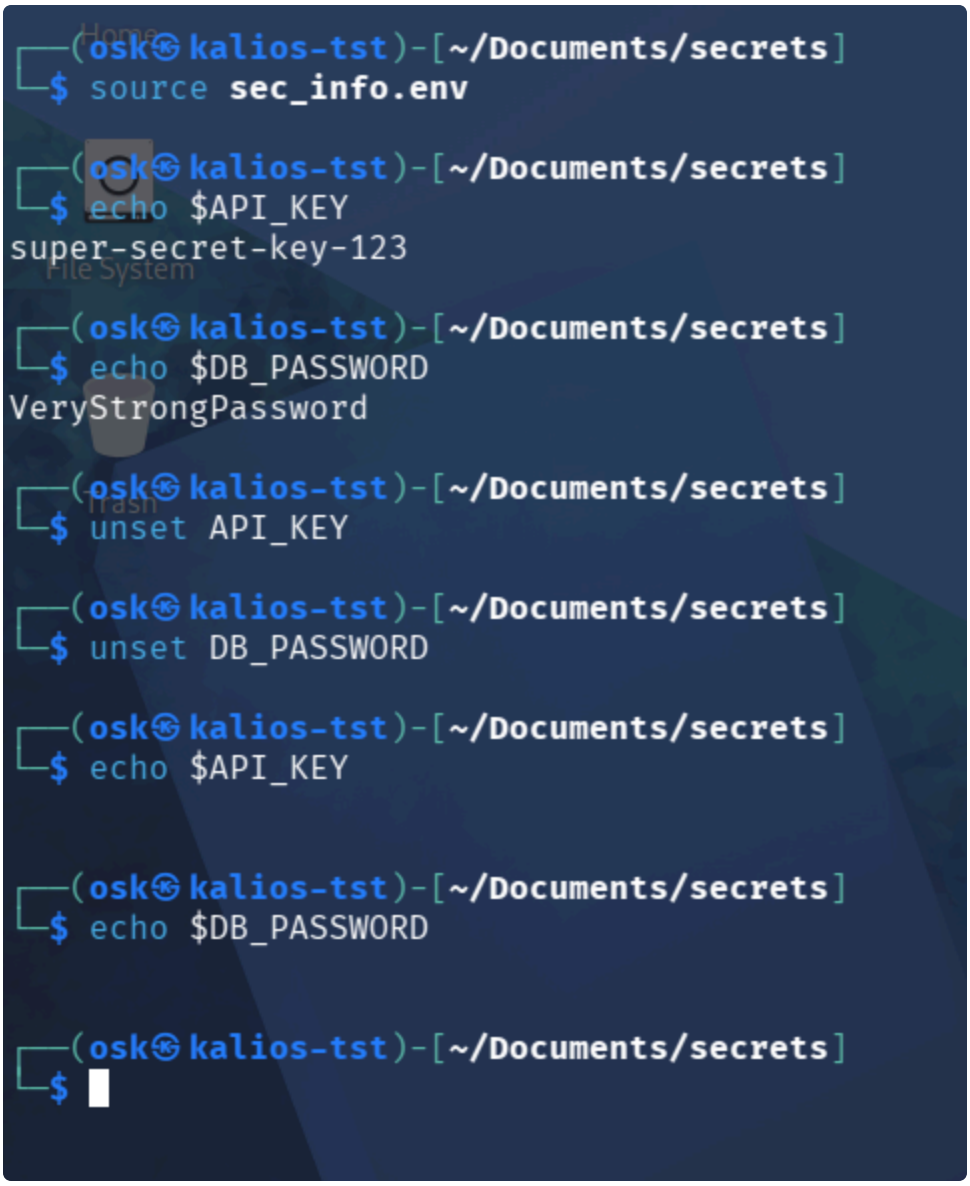
4 - Asymmetric Encryption:

Of course asymmetric encryption can also be used:



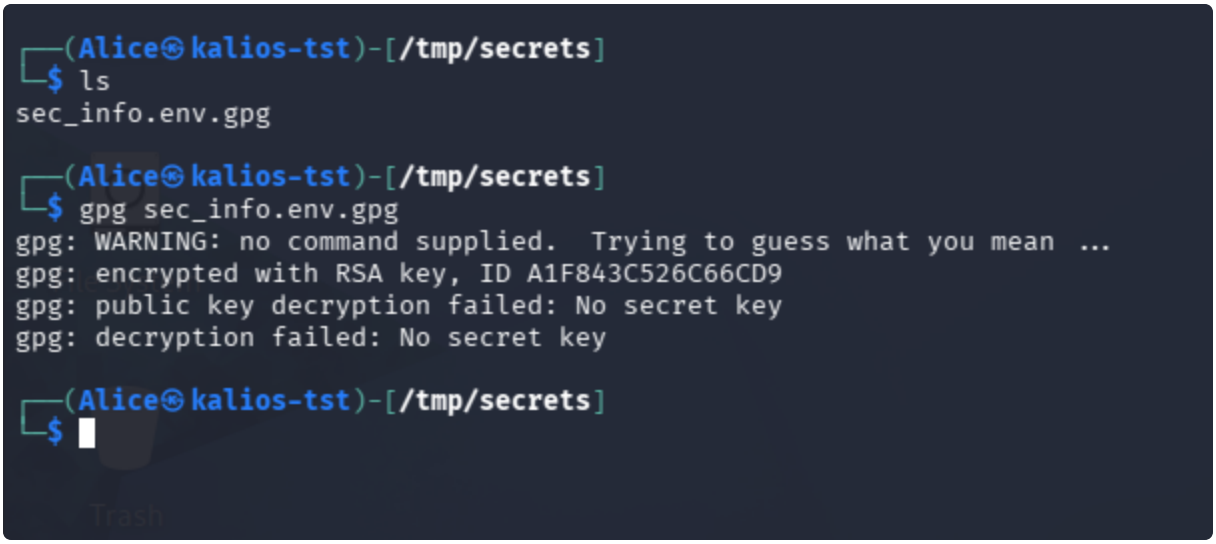
5 - Using the Secret:

We can use the secret (which sets some pre-defined environment variables), we make sure to unset the values after usage



6 - Access Without Secret:

We can login as a different user and try and open the (leaked) encrypted file, of course, this will fail



Additional:

We can encrypt a given secret file for multiple recipients simply by adding multiple `--recipient` arguments to the `gpg --encrypt` command:
`gpg --encrypt --armor --recipient bob@example.com --recipient alice@example.com sec_info.env`

We can also decrypt the file and run it via stdin.
`gpg --decrypt sec_info.env.gpg | source /dev/stdin`
where after the file is decrypted, the output goes to stdout, which is piped to stdin which runs source on that stdin input, which will automatically run the contents of the decrypted file, without the decrypted file ever touching the filesystem.

Closing Thoughts:

1. Why don't secrets belong in the source code? : Because they can be extracted either by decompiling or simply reading in cases where they are leaked in plain within a code repository
2. What is the difference between symmetric and asymmetric secret encryption? - Symmetric uses a shared key/secret to encrypt contents, which is a system where if the passphrase is compromised anybody can read it, while asymmetric works on PKI and only the owner of a private key can read what was encrypted using their public key.
3. What happens if we lose the private key? - If loss happens in cases of a leak the secret data can now be understood as compromised and should be altered and re-secured. Alternatively if the owner simply loses their private key they will not be able to access the data that was secured
4. How would you handle this in a larger enterprise? - Centralized solutions for keeping secrets, implementing an authentication based access control and audits.